

Web Application PenTest on Juice Shop

Objective: Identify, analyze, and exploit vulnerabilities in Juice Shop while documenting findings and providing remediation recommendations.

Scope:

- Perform reconnaissance, scanning, and vulnerability assessment.
- Exploit vulnerabilities to demonstrate security flaws.
- Document findings and suggest security improvements.
- **Tools:** *Nessus, Burp Suite, OpenVAS, SQLMap, OWASP ZAP, Google Dorking, owasp-zap, Wappalyzer, sqlmap, gospider, whois, nmap, nslookup.*

Team Members & Roles:

Each member is responsible for a specific vulnerability from scanning to exploitation.

- Shahd – CSRF
 - Mark – SQL Injection
 - Hassan – XSS
 - Mohamed – Broken Authentication / CORS
-

Week 1: Information Gathering & Reconnaissance

Tasks:

- Use OSINT techniques (*Google Dorking, WHOIS lookup, NSLookup, Sublist3r*).
- Identify technologies (*Node.js, Angular, SQLite*) using *WhatWeb, Wappalyzer*.
- Map potential attack surfaces (*login forms, search fields, APIs*) using *GoSpider, Nmap*.

Deliverable:

- Recon report including identified technologies, discovered endpoints, and exposed data.
-

Week 2: Vulnerability Scanning & Enumeration

Tasks:

- *Run Nessus, OpenVAS, and OWASP ZAP* to detect vulnerabilities.
- Analyze authentication flaws, misconfigurations, and exposed sensitive files.
- Identify *SQLi, XSS, CSRF, and IDOR* vulnerabilities.

Deliverable:

- Scan report listing vulnerabilities with severity ratings.
-

Week 3: Exploitation & Proof of Concept

Tasks:

- Use *Burp Suite, SQLMap, and manual payloads* to exploit vulnerabilities.
- Perform privilege escalation and authentication bypass tests.
- Demonstrate *CSRF, XSS, and SQLi* exploitation.

Deliverable:

- Exploitation report with attack details, screenshots, and payloads used.
-

Week 4: Reporting, Remediation & Presentation

Tasks:

- Document vulnerabilities, risk levels, and remediation steps.
- Assign CVSS scores and provide mitigation recommendations.
- Prepare a final presentation summarizing key findings.

Deliverable:

- Final penetration testing report.
- Presentation slides for stakeholders.